SECAI+ LESSON 6.3.3

Organizational AI Policies

How enterprises define permitted use, assign accountability, and control risk across the full AI lifecycle.

What Makes a Policy Effective?

The Foundation of a Corporate AI Policy

What Is Permitted

Approved tools, platforms, and use cases clearly defined

Who Is Accountable

Roles and responsibilities assigned across teams

How Risk Is Controlled

Guardrails across the full AI lifecycle

Effective policies translate enterprise risk into **everyday actions** employees and vendors can follow, no deep technical expertise required.

Chapter 1

Sanctioned vs. Unsanctioned AI

✅ Sanctioned AI

- Vetted and approved by the organization
- Configured for security & privacy requirements
- Supported by IT and Legal
- SSO-enabled, monitored, auditable

⚠️ Shadow AI (Unsanctioned)

- Tools adopted independently by employees
- Free web LLM interfaces
- Browser extensions accessing external services
- No oversight, unknown data handling

Policy goal: not just discourage unsafe tools but create **safe, high-utility alternatives employees prefer** to use.

The Pre-Approved AI Catalog

Mature programs build a **searchable catalog** of vetted AI assistants reducing shadow AI by making the safe option the easy option.

Searchable Catalog

Employees find the right tool fast, without going rogue

SSO Integration

One login, centrally managed access and audit trail

Clear Usage Guidance

What the tool is for, what data is allowed, how to use it

Chapter 2

Public vs. Private AI Models

🌐 Public Models

Cloud services shared among customers

- Prompt & output may be stored by provider
- Data potentially used for model training
- Subject to jurisdictional regulations

🔒 Private Models

Deployed in isolated environments

- Dedicated tenant, VPC, or on-premises
- Control over data residency, keys & logging
- Greater engineering overhead

Policy should establish **decision criteria**, not blanket bans.

Choosing the Right Model: A Risk Framework

Low-Risk Use Case

Example: Generic brainstorming, drafting templates

→ Public model with strong data-use guarantee may be acceptable

High-Risk Use Case

Example: Sensitive health or financial records

→ Private model with data isolation, customer-managed encryption keys, and contractual no-training assurances

The policy should match **model deployment type** to the sensitivity of the use case not apply one rule to all.

Chapter 3

Sensitive Data Governance

AI policy must align with the organization's **data classification scheme** and specify rules for each tier.

Public

Freely shareable, minimal restriction

Internal

No-retention models only

Confidential

Automatic redaction required

Restricted

Must not leave trust boundary

Per-Classification Policy Requirements

For each data class, your policy must specify:

1

Permitted Uses

Training, fine-tuning, RAG, prompting — which are allowed?

2

Permitted Model Types

Public, private, or on-premises only?

3

Data Handling

Required masking, tokenization, or redaction

4

Logging & Retention

Audit trail requirements and retention limits

Starting Without a Mature Classification System

No formal data classification yet? Begin with **simplified restricted rules** for the highest-risk data types.

Source Code

Treat as restricted. Do not send to public models

Credentials & Secrets

API keys, passwords are never in prompts

Customer PII

Names, emails, health data require redaction

Unreleased Products

Roadmaps, designs are confidential by default

Simplified rules beat no rules. Formalize classification as your program matures.

Lesson 6.3.3

Key Takeaways

1. **Policy enables safe adoption**
   Clear AI policies define permitted tools, accountability, and risk controls not just restrictions.

2. **Fight Shadow AI with better alternatives**
   Offer a vetted catalog with SSO and guidance so employees choose sanctioned tools by default.

3. **Match model type to risk level**
   Low-risk uses may allow public models; sensitive data requires private deployment with contractual protections.

4. **Govern data by classification**
   Align AI policy with your data tiers. Specify permitted uses, masking requirements, and retention limits for each class.